

Agent Identity Control Plane — Comparative Analysis

Version: 2025-12-25 • Focus: Identity, intent, and action governance (vs. mesh/orchestration).

What changed (Mesh → Identity)

The prior framing centered on an “agent mesh” (connectivity + observability). The reworked framing targets a sharper, unsolved pain: **agents (and humans using AI) turning untrusted content into actions**. The platform's core primitive becomes **intent-bound capabilities** (who/what/how long) and **action receipts** (provable audit of what happened and why it was allowed).

Problem definition (the core pain today)

Identity + intent drift is the failure mode: an agent is authenticated, but not continuously constrained to the user's intent. Tool calls (OAuth, GitHub, Jira, email, cloud) become a high-leverage exfil/abuse surface. Prompt injection is hard to eliminate completely, so the system must assume the model can be manipulated and enforce safety at the **action boundary**.

Platform architecture (reference)

Conceptual layout:

CONTROL PLANE

- Policy-as-code (ABAC): who/what/resource/time/risk
- Capability issuer: mint intent-bound tokens (scoped, time-limited)
- Approvals & exceptions: JIT elevation, break-glass
- Registry: agents, tools, MCP servers, connectors
- Evidence queries: investigation UX + SIEM exports

ENFORCEMENT PLANE

A) Tool Gateways / Adapters

- MCP gateway / tool proxy
- OAuth broker + session binding
- Secrets & credential vault (scoped credentials)
- Response filters + data minimization

B) Workflow Interceptors (optional; differentiating for "shadow AI")

- Browser extension + IDE plugin + local proxy
- Pre-exfil classification/redaction
- "Use approved agent" re-route

EVIDENCE PLANE

- Tamper-evident action ledger (“receipts”)
- Trace graph: prompt → tool calls → side effects
- Retention + hashing + WORM option

Where this sits relative to existing categories

Most existing products solve *one* slice: (1) AI gateways for app-to-model calls, (2) cloud runtimes for agents, or (3) browser/SSE controls for employee GenAI. The Identity Control Plane targets the seam between them: **uniform intent-bound authorization + runtime enforcement + receipts** across vendors and environments.

Comparison matrix (high level)

Option	Best at	Gaps vs. our goal	How we coexist
AWS Bedrock AgentCore Policy + Gateway + Identity	Managed AWS agent runtime and tool gateway; policy boundary for agent→tool interactions.	Primarily AWS-scoped. Doesn't govern non-AWS agents, endpoint shadow AI, or unify receipts across vendors by default.	Treat AgentCore as an enforcement target; normalize events into a single receipt ledger & investigation UX.
Microsoft Copilot ecosystem Copilot Studio + tenant controls	Strong inside M365/Copilot: agent build/deploy patterns and tenant governance controls.	Ecosystem-scoped; uneven coverage for third-party tools/MCP and non-Microsoft runtimes.	Add as another domain: ingest consent/tool actions, attach intent-bound approvals, unify receipts.
Zenity AI agent security & governance	Agent discovery + posture + runtime detections, especially in Copilot/Power Platform environments.	Less positioned as universal capability broker for arbitrary tool gateways and multi-runtime intent tokens.	Partner/compete: we can provide capability issuance + receipts that Zenity consumes for response workflows.
MCP gateways (e.g., Tetrade MCP Gateway)	Central auth & filtering for agent-to-tool traffic over MCP.	By itself: limited approvals UX, org-wide intent binding, cross-runtime receipts, and shadow AI coverage.	Use as dataplane; we supply capability tokens, approval flows, receipts, and SOC workflows.
AI gateways (e.g., Kong AI Gateway)	Model routing + prompt governance + PII sanitization for app-to-model calls.	Focuses on prompt/response boundary, not tool-action boundary or intent enforcement for side effects.	Complementary: AI gateway for LLM calls; our plane for tool calls + action receipts.

Differentiators that matter (non-hand-wavy)

- **Intent-bound capabilities:** every tool call must present a scoped, time-limited capability minted from user intent (human approval optional per risk).
- **Action receipts:** tamper-evident record tying each side-effect (API call, write, deletion) to policy decision + credential scope + upstream context.
- **Credential brokering:** never hand raw OAuth tokens/secrets to models; broker tool access through short-lived, least-privilege grants.
- **Cross-runtime normalization:** unify receipts across AWS AgentCore, Copilot, MCP servers, self-hosted agents, and “human shadow AI” interceptors.

MVP build plan (90-day credible)

- **Capability Broker:** issue JWT-style capability tokens with ABAC claims (user, agent, tool, resource, TTL, risk).
- **Tool Proxy:** start with 2–3 high-risk tools (GitHub, Jira, Slack or Google Drive). Enforce capability check before every action.
- **Receipt Ledger:** append-only store with hash-chaining; basic investigation UI + SIEM export.
- **One integration path:** MCP gateway adapter OR direct tool proxy (choose fastest).

Source notes (selected)

[1] AWS blog: “Amazon Bedrock AgentCore adds quality evaluations and policy controls for deploying trusted AI agents” (Dec 2, 2025).

[2] AWS docs: AgentCore Policy and Gateway (tool boundary, OAuth handling, auditing).

[3] Zenity: AI Agent Security & Governance platform positioning and Copilot Studio coverage.

[4] Tetrade MCP Gateway: authenticated access and filtering to govern agent-tool interactions.

[5] Kong AI Gateway: governance on prompts + built-in PII sanitization for LLM calls.

[6] Reporting on Copilot Studio token/consent abuse (“CoPhish”), highlighting OAuth/consent risk in agent workflows.